

Emnekode: GRC1100

Emnenavn: Governance, Risk and Compliance

Eksamensform - Vurderingskombinasjon: Individuell hjemmeeksamen

Eksamensdato: 13.02.2026

Tillatte hjelpemidler: Alle hjelpemidler tillatt

Filformat: Pdf

Språk: Kan besvares på Norsk eller Engelsk

Plagiatkontroll:

Det gjennomføres plagiatkontroll på alle innleveringer, bacheloroppgaver og masteroppgaver. Se for øvrig retningslinjene for kildehenvisning, plagiat og formelle krav til innlevering.

Alle besvarelser skal ha med «Deklarasjon for bruk av AI-hjelpemidler og verktøy».

Veiledning til besvarelse:

- Hver oppgave har en anbefalt sidebegrensning. Studenten kan selv fordele sidene mellom oppgavene, men den totale besvarelsen skal ikke overstige 15 sider med oppgavebesvarelser.
- En ideell innlevering består av: forside, innholdsfortegnelse, KI-erklæring, inntil 15 sider besvarelse, og referanseliste.
- Skjemaet Erklæring om bruk av KI-verktøy og ressurser (siste side i oppgaveteksten) skal fylles ut og plasseres før besvarelsen i rapporten. (Denne siden regnes ikke som en del av sidebegrensningen på 15 sider.)
- Bruk Arial eller Calibri, skriftstørrelse 11–12 pt, med 1,5 linjeavstand.
- Bruk tabeller og visualiseringer aktivt i besvarelsen.
- Inkluder alltid forklarende tekst sammen med tabeller og bilder for å gi kontekst.
- På spørsmål om NIS2 henvises det til selve teksten fra direktivet og ikke tilhørende veiledere.
- Oppgi kilder for å underbygge antakelser eller valg gjort i besvarelsen. Det viktigste er at referansene brukes korrekt og hensiktsmessig. Foretrukket referansestil er IEEE / Vancouver eller APA.

Eventuell annen eksamensinformasjon:

- Start innlastingen av oppgaven i god tid, da det kan ta lang tid å laste den opp
- Eksamensbesvarelser som ikke leveres inn i Wiseflow innen angitt klokkeslett går ikke videre til sensur
- Husk å sjekke at alle filer lar seg åpne og at alle filer er med i innleveringen. Her kan det være lurt å sjekke de lagrede filene på flere maskiner før du leverer i Wiseflow
- Feil filformat og/eller mangelfull leveranse kan føre til at leveransen ikke blir vurdert/bestått.
- Den totale filstørrelsen på hele besvarelsen må ikke overstige 5GB ved zip format eller 5MB ved PDF format

Oppgave #	Tittel	Poeng/ 100
O1	Sikkerhetsstrategi og etterlevelse (4 sider)	25
O2	Overordnet Risikovurdering (8 sider)	40
O3	Avvik- og hendelseshåndtering (3 sider)	15
	Overordnet kvalitet, bruk av rammeverk/verktøy/standarder og presentasjon.	20
Total		100

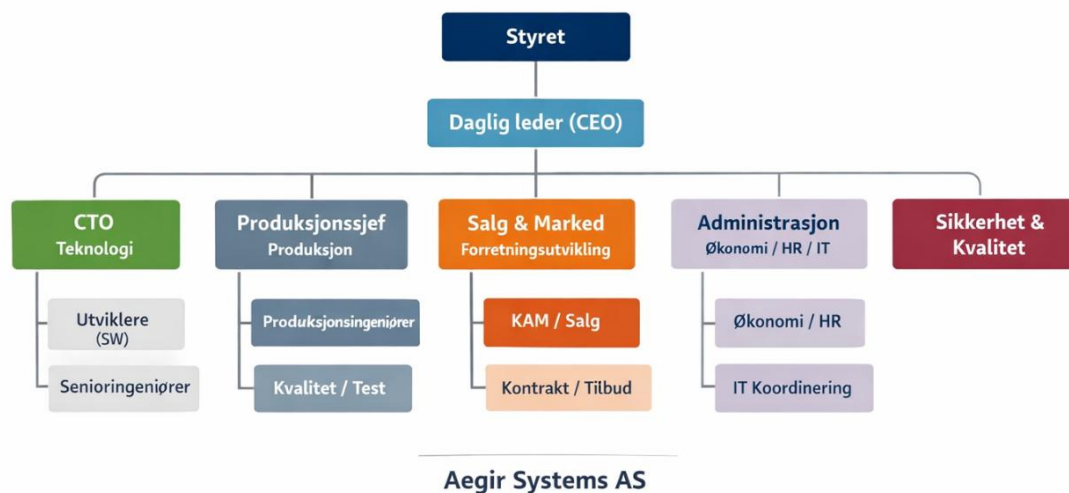
Case: Aegir Systems AS (Fiktiv bedrift)

Merk: Kandidaten kan legge til realistiske og relevante opplysninger til caset ved behov. Slike tillegg skal kort markeres i teksten, for eksempel ved å innlede med «Basert på informasjon innhentet fra virksomheten ...».

Aegir Systems AS er en norsk teknologibedrift etablert i 2016, lokalisert i Raufoss industripark. Selskapet har rundt 30 ansatte og leverer høyspesialiserte teknologikomponenter til den norske og europeiske forsvarsindustrien. Aegir er en underleverandør i større leveransekjeder og har ingen direkte kontakt med sluttbruker.

Selskapets hovedprodukt er en kritisk elektronisk og programvarebasert komponent som inngår i et moderne våpensystem. Komponentene muliggjør fjernstyring av våpensystemene og leveres sammen med styringsprogramvare. Komponentene produseres i små serier og må gjennom en proprietær produksjons- og kalibreringsprosess før levering. Denne prosessen er utviklet internt over flere år og anses som selskapets viktigste konkurransefortrinn. Kun et fåtall ansatte har full innsikt i hele prosessen.

Aegir jobber tett med én hovedkunde, men har også pågående dialog med nye internasjonale aktører. Kundene stiller strenge krav til konfidensialitet, leveringspresisjon og kvalitet. Flere prosjekter er underlagt kontraktsfestede taushetskrav, og deler av informasjonen selskapet håndterer er sensitiv.



Aegir Systems AS er organisert funksjonelt, med korte beslutningslinjer og tydelig operativt ansvar.

- Styret - Overordnet strategisk og juridisk ansvar.
- Daglig leder (CEO) - Overordnet ansvar for strategi, kontrakter, kunder, myndighetsdialog og prioriteringer. Koordinerer tverrgående ansvar som sikkerhet og etterlevelse.
- CTO (Teknologi) - Ansvar for produktutvikling, programvare, teknisk arkitektur og utviklingsverktøy. Leder utviklere og senioringeniører. Støtter IT-drift sammen med administrasjon.
- Produksjonssjef (Produksjon) - Ansvar for produksjonslinje, kvalitet, test og leveranser. Har nøkkelrolle i den hemmelige produksjons- og kalibreringsprosessen.
- Salg & marked (Forretningsutvikling) - Ansvar for kundedialog, tilbud, kontrakter og nøkkelkunder (KAM). Håndterer NDA-er og kravdokumenter.
- Administrasjon (Støttefunksjoner) - Økonomi, HR og IT-koordinering. Ingen dedikert IT- eller sikkerhetsrolle.
- Sikkerhet & kvalitet (tverrgående ansvar) - Ikke egen avdeling. Ansvar delt mellom CEO, CTO og produksjonssjef.

Organisasjonen er liten, kompetansetung og personavhengig, med flere roller som kombinerer operativ drift og styringsansvar.

Drift og arbeidsform

Selskapet kombinerer:

- lokal produksjon i sikrede lokaler
- digital produktutvikling og dokumentasjon kombinert sky og onprem
- bruk av eksterne leverandører for enkelte komponenter og tjenester

Utvikling skjer hovedsakelig på moderne skybaserte verktøy, mens produksjonsutstyr og testmiljøer er lokalt driftet (onsite). Flere ansatte har fleksibel arbeidshverdag, og noe arbeid, spesielt på software, utføres fra hjemmekontor.

Aegir Systems AS er i vekst og vurderer å utvide både produksjonskapasitet og kundebase. Samtidig opplever ledelsen at virksomheten har gått fra å være en liten teknologigründerbedrift til å bli en strategisk viktig leverandør, med tilhørende ansvar og forventninger. Selv om bedriften leverer til forsvarsindustri, har den interne sikkerheten dessverre ikke vært en hovedsatsing.

IT-bruk og digitale arbeidsprosesser

Aegir Systems AS er i stor grad avhengig av IT-systemer for daglig drift, utvikling og samarbeid, selv om den mest sensitive produksjonen foregår lokalt. IT-landskapet har vokst gradvis og er preget av pragmatiske og kostnadseffektive valg.

Programvareutvikling, algoritmedesign og tilhørende teknisk dokumentasjon skjer ved bruk av skybaserte utviklings- og samhandlingsverktøy. Kildekode, konfigurasjoner og tekniske beskrivelser lagres i skybaserte kode- og dokumentasjonsplattformer. Tilgang styres hovedsakelig gjennom brukerkontoer, og samarbeid skjer både fra kontor og hjemmekontor.

Den utviklede programvaren og konfigurasjonsdataene inngår som en del av den fysiske komponenten som produseres lokalt. Produksjonsmiljøet er fysisk adskilt fra utviklingsmiljøet, men støttes av lokalt driftede IT-systemer for styring av produksjonsparametere, logging og kvalitetssikring, samt dokumentasjon av kalibrering og testresultater. Disse systemene er tett knyttet til spesialisert produksjons- og testutstyr.

Overføring av programvare, konfigurasjoner og teknisk dokumentasjon fra utvikling til produksjon skjer gjennom definerte overleveringer. Samtidig er deler av prosessen personavhengig, og nøkkelpersonell besitter detaljkunnskap om sammenhengen mellom programvare, produksjonsparametere og ferdig produkt.

Bedriften har en aktiv skystrategi og benytter i hovedsak standardiserte skytjenester («hylleware») for å støtte administrative og forretningsmessige funksjoner. Dette gjør at virksomheten kan konsentrere seg om kjernevirksomheten. Administrasjon og støttefunksjoner benytter skybaserte forretningssystemer for økonomi og fakturering, HR og personaloppfølging, samt e-post og intern kommunikasjon. Det finnes ingen dedikert IT- eller sikkerhetsansvarlig. Drift, brukertilgang og tekniske beslutninger håndteres i hovedsak av CTO, med støtte fra eksterne leverandører ved behov.

Flere ansatte benytter bærbare arbeidsstasjoner både på kontoret og hjemme. Det er varierende praksis for lagring av arbeidsfiler, bruk av eksterne lagringsmedier og håndtering av tilganger. Enkelte senioringeniører har utvidede rettigheter for å kunne løse komplekse tekniske problemstillinger effektivt.

Selskapet er i ferd med å inngå nye kontrakter som kan innebære tettere integrasjon med kunders systemer, økte krav til dokumentasjon av utviklings- og produksjonsprosesser, samt mer strukturert håndtering av tilgang, logging og sporbarhet. Ledelsen er klar over at IT-bruken er forretningskritisk, men opplever at tempo, konfidensialitet og operativ effektivitet ofte prioriteres fremfor formelle prosesser.

Oppgave 1: Sikkerhetsstrategi og etterlevelse (4 sider)

Beskrivelse: Selskapet planlegger å levere produkter til flere kunder og nye markeder. Dette medfører økte krav til dokumentert etterlevelse og digital sikkerhet for å oppnå og opprettholde markedstilgang.

Du er engasjert som ekstern konsulent i YouFearWeProfit AS og har fått i oppdrag å bistå Aegir Systems AS med å strukturere og gjennomføre nødvendig etterlevelsesarbeid for å møte disse kravene.

Oppgaver:

1. Diskuter hva begrepene konfidensialitet, integritet og tilgjengelighet vil ha å si for sikkerhetsarbeidet i Aegir Systems AS.
2. Lag en overordnet prosjektplan for hvordan virksomheten kan oppnå etterlevelse av NIS2 kapittel 4, artikkel 20 og 21. Prosjektplanen skal inneholde hovedfaser, milepæler og sentrale leveranser, men ikke detaljert teknisk implementering.
(Lenke NIS2 https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32022L2555#cpt_IV).
3. Diskuter hvilke organisatoriske og styringsmessige konsekvenser NIS2 - artikkel 24 kan få for virksomheten.
4. Utarbeid en kort, overordnet sikkerhetspolicy (maks 1 side) som fastsetter mål og prinsipper for virksomhetens GRC-arbeid knyttet til NIS2. Relevante bestemmelser i kapittel 4 skal reflekteres i policyen og kan henvises til med artikkel nr og bokstav.

Oppgave 2: Strategisk risikovurdering (8 sider)

Beskrivelse: Som en del av arbeidet mot NIS2 compliance skal det innføres risikostyring. Det første steget i denne prosessen er å gjennomføre en strategisk risikovurdering av den digitale sikkerheten i bedriften. Denne vurderingen skal legge grunnlaget for den videre sikkerhetssatsingen. I oppgave 2.1 etablerer du konteksten som benyttes for å besvare oppgave 2.2, 2.3 og 2.4.

Oppgaver:

1. For å **etablere og avgrense kontekst** i risikovurderingen skal du:
 - Identifisere og beskrive virksomhetens viktigste leveranser/tjenester.
 - Kartlegge og beskrive de fire mest sentrale kjerneprosessene som er nødvendige for å levere disse.
 - Avgrense konteksten for risikovurderingen basert på leveranser og kjerneprosesser.
2. **Verdi-, trussel- og sårbarhetsvurdering:**
 - Gjennomfør en verdivurdering innenfor den konteksten du har definert. Identifiser og beskriv de ti viktigste digitale verdiene virksomheten forvalter (for eksempel informasjon, systemer, programvare, konfigurasjoner eller data). Klassifiser hver verdi med hensyn til krav til konfidensialitet, integritet og tilgjengelighet (CIA).
 - Gjennomfør en trusselvurdering for bedriften. Fokuser på de fem viktigste trusselaktørene og analyser trusselens motivasjon, intensjonen, evne, kunnskap (know how) og vilje til å angripe Aegir Systems AS. Vurderingene skal være begrunnet i virksomhetens rolle, teknologi og marked.
 - Gjennomfør en overordnet sårbarhetsvurdering av Aegir Systems AS innenfor din definerte kontekst. Identifiser hvor virksomheten er mest eksponert i organisasjon, IT- og produksjonsmiljø, leveranser og kjerneprosesser. Sårbarhetene skal presenteres strukturert (for eksempel i

tabellform) og prioriteres i henhold til kritikalitet.

3. Overordnet risikovurdering:

- Gjennomfør en strategisk risikovurdering av bedriften og kartlegg uakseptabel risiko på et overordnet nivå. Bruk arbeidet ditt fra verdi-, trussel- og sårbarhetsvurderingene til å ankre risikoene.
- **Visualisering:** Bruk visuelle verktøy aktivt til å framstille risikobildet, forklare kritiske risikoer og overbevise mottakeren.

4. Tiltaksanbefaling:

- Oppsummer funnene dine med fem til ti tiltaksanbefalinger til virksomhetens ledelse for å redusere risiko, sikre virksomheten og tjenesteleveranser. Samkjør gjerne tiltaksanbefalingene dine med strategi og NIS2-arbeidet fra oppgave 1.
- Skriv et notat til ledelsen om hvorfor de bør investere i tiltaksplanen din. Bruk logos, pathos og ethos aktivt for å overbevise. Du kan også bruke visuelle hjelpemidler for å overbevise.

Oppgave 3: Avvik- og hendelseshåndtering (3 sider)

Beskrivelse: En utvikler i Aegir Systems AS oppdager at en intern konfigurasjonsfil med produksjonsparametere og krypteringsnøkler ligger tilgjengelig i et skybasert utviklingsmiljø med bredere tilgang enn forutsatt. Filen inneholder sensitiv informasjon knyttet til både programvare og produksjonsoppsett.

Oppgaver:

1. Avvikssystem:

- Beskriv og design en avvikshåndteringsprosess for Aegir Systems AS, fra innmelding til ferdig håndtert og lukket avvik (non-conformity).
- Bruk avviket beskrevet ovenfor som eksempel på avviksbehandlingen.

Eskalering: Forholdet registreres som et avvik i virksomhetens kvalitetssystem og klassifiseres initialt som en «feil tilgangskonfigurasjon» og blir håndtert der etter.

Noen dager senere mottar virksomheten en henvendelse fra en samarbeidspartner som har observert uvanlig trafikk knyttet til Aegir Systems' miljøer. Det viser seg at en ekstern IP-adresse har hatt tilgang til utviklingsplattformen i perioden filen var eksponert.

2. Hendelseshåndtering:

- Forklar forskjellen mellom avvik og sikkerhetshendelse (incident). Diskuter når og hvorfor avviket i scenarioet bør reklassifiseres til en sikkerhetshendelse, og hvilke forhold som kan medføre ytterligere eskalering til krise.
- Beskriv hvilke hovedelementer som bør inngå i en hendelseshåndteringsplan (incident response plan) for Aegir Systems AS. Bruk konkrete eksempler fra virksomhetens organisasjon, teknologi og leveranser.
- Beskriv hvordan hendelsen i scenarioet bør håndteres steg for steg i tråd med beste praksis. Redegjør også for hvilken IT-systemstøtte virksomheten vil være avhengig av for effektiv hendelseshåndtering.

Kopier AI deklarasjonen nedenfor til besvarelsen din og fyll ut.

Deklarasjon for bruk av AI-verktøy og hjelpemidler

Sjekklisten nedenfor skal besvares:

- **Tekstkorreksjon:** Er deler av teksten sjekket med verktøy som Grammarly, Ginger, LanguageTool eller lignende? Ja / Nei
- **Tekstgenerering:** Er deler av teksten generert av verktøy som ChatGPT, Jasper, WriteSonic eller lignende? Ja / Nei
- **Skriveassistanse:** Har noen av rapportens ideer eller tilnærminger blitt foreslått av verktøy som ChatGPT, Google Bard eller lignende? Ja / Nei
- **Bildegenerering:** Er noen bilder/figurer i rapporten generert av verktøy som Midjourney, Dall-E eller lignende? Ja / Nei
- **Andre AI-verktøy:** Har du brukt andre AI-verktøy? Hvis ja, spesifiser her:

Har du brukt noen AI-baserte verktøy eller hjelpemidler i utarbeidelsen av denne rapporten?

Hvis ja, spesifiser verktøyet og bruksområdet nedenfor.

1. **Tekst generering** - Hvis du har brukt teksthjelpemidler/verktøy, hvilke oppgaver ble løst ved hjelp av AI og hvordan?
2. **Bilder, tabeller og figurer** Hvis du har brukt bilde-/figurgeneratorer, hvilke bilder/diagrammer er AI genererte?

Jeg erklærer at all bruk av AI-verktøy eller hjelpemidler er tydelig oppgitt enten i rapporten eller i dette deklarasjonsskjemaet.

Kandidatnr / Dato

Emnekode: GRC1100

Emnenavn: Governance, Risk and Compliance

Eksamensform - Vurderingskombinasjon: Individuell heimeksamen

Eksamensdato: 13.02.2026

Tillatte hjelpemidler: Alle hjelpemidler tillat

Filformat: Pdf

Språk: Kan besvares på Norsk eller Engelsk

Plagiatkontroll:

Det blir gjennomført plagiatkontroll på alle innleveringar, bacheloroppgåver og masteroppgåver. Sjå elles retningslinjene for kjeldetilvising, plagiat og formelle krav til innlevering.

Alle besvarelser skal innehalde «Deklarasjon for bruk av KI-hjelpemiddel og verktøy».

Rettleiing til besvarelse:

- Kvar oppgåve har ei tilrådd sideavgrensing. Studenten kan sjølv fordele sidene mellom oppgåvene, men den samla besvarelsen skal ikkje overstige 15 sider med oppgåvesvar.
- Ein ideell innlevering består av: framside, innholdsfortekning, KI-erklæring, inntil 15 sider besvarelse og referanseliste.
- Skjemaet *Erklæring om bruk av KI-verktøy og ressursar* (siste side i oppgåveteksten) skal fyllast ut og plasserast før besvarelsen i rapporten. (Denne sida blir ikkje rekna som ein del av sideavgrensinga på 15 sider.)
- Bruk Arial eller Calibri, skriftstorleik 11–12 pt, med 1,5 linjeavstand.
- Bruk tabellar og visualiseringar aktivt i besvarelsen.
- Inkluder alltid forklarande tekst saman med tabellar og bilete for å gi kontekst.
- Ved spørsmål om NIS2 skal det visast til sjølve direktivteksten, ikkje til tilhøyrande rettleiarar.
- Oppgi kjelder for å underbyggje antakingar eller val som er gjorde i besvarelsen. Det viktigaste er at referansane blir brukte korrekt og formålstenleg. Føretrekt referansestil er IEEE/Vancouver eller APA.

Eventuell annan eksamensinformasjon:

- Start opplastinga av oppgåva i god tid, då det kan ta lang tid å laste ho opp.
- Eksamensbesvarelser som ikkje er leverte i Wiseflow innan oppgitt klokkeslett, går ikkje vidare til sensur.
- Hugs å kontrollere at alle filer kan opnast, og at alle filer er med i innleveringa. Det kan vere lurt å sjå over dei lagra filene på fleire maskiner før du leverer i Wiseflow.
- Feil filformat og/eller mangelfull levering kan føre til at besvarelsen ikkje blir vurdert eller bestått.
- Den samla filstorleiken for heile besvarelsen må ikkje overstige 5 GB i zip-format eller 5 MB i PDF-format.

Oppgåve #	Tittel	Poeng/ 100
O1	Sikkerhetsstrategi og etterlevelse (4 sider)	25
O2	Overordna Risikovurdering (8 sider)	40
O3	Avvik- og hendelseshandtering (3 sider)	15
	Overordna kvalitet, bruk av rammeverk/verktøy/standardar og presentasjon.	20
Total		100

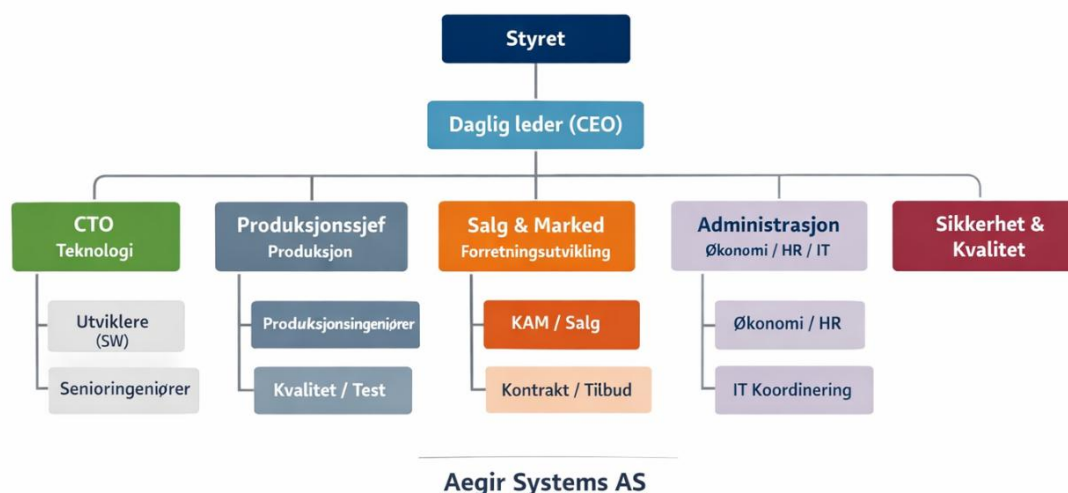
Case: Aegir Systems AS (Fiktiv bedrift)

Merk: Kandidaten kan leggje til realistiske og relevante opplysningar i caset ved behov. Slike tillegg skal kort markerast i teksten, til dømes ved å innleie med: «Basert på informasjon innhenta frå verksemda ...».

Aegir Systems AS er ei norsk teknologiverksemd etablert i 2016, lokalisert i Raufoss industripark. Selskapet har om lag 30 tilsette og leverer høgspesialiserte teknologikomponentar til norsk og europeisk forsvarsindustri. Aegir er ein underleverandør i større leveransekjeder og har ingen direkte kontakt med sluttbrukar.

Selskapet sitt hovudprodukt er ein kritisk elektronisk og programvarebasert komponent som inngår i eit moderne våpensystem. Komponentten gjer fjernstyring av våpensystem mogleg og blir levert saman med styringsprogramvare. Komponentten blir produsert i små seriar og må gjennom ein proprietær produksjons- og kalibreringsprosess før levering. Denne prosessen er utvikla internt over fleire år og blir rekna som verksemda sitt viktigaste konkurransefortrinn. Berre eit fåtal tilsette har full innsikt i heile prosessen.

Aegir samarbeider tett med éin hovudkunde, men har òg pågåande dialog med nye internasjonale aktørar. Kundane stiller strenge krav til konfidensialitet, leveringspresisjon og kvalitet. Fleire prosjekt er underlagde kontraktsfesta tieplikt, og delar av informasjonen verksemda handterer, er sensitiv.



Aegir Systems AS er organisert funksjonelt, med korte avgjerdslinjer og tydeleg operativt ansvar.

- Styret – Overordna strategisk og juridisk ansvar.
- Dagleg leiar (CEO) – Overordna ansvar for strategi, kontraktar, kundar, dialog med styresmakter og prioriteringar. Koordinerer tverrgåande ansvar som tryggleik og etterleving.
- CTO (Teknologi) – Ansvar for produktutvikling, programvare, teknisk arkitektur og utviklingsverktøy. Leiar utviklarar og senioringeniørar. Støttar IT-drift saman med administrasjonen.
- Produksjonssjef (Produksjon) – Ansvar for produksjonslinje, kvalitet, testing og leveransar. Har ei nøkkelrolle i den hemmelege produksjons- og kalibreringsprosessen.
- Sal og marknad (Forretningsutvikling) – Ansvar for kundedialog, tilbod, kontraktar og nøkkelkundar (KAM). Handterer NDA-ar og kravdokument.
- Administrasjon (Støttefunksjonar) – Økonomi, HR og IT-koordinering. Ingen dedikert IT- eller tryggleiksrolle.
- Tryggleik og kvalitet (tverrgåande ansvar) – Ikkje eiga avdeling. Ansvar delt mellom dagleg leiar, CTO og produksjonssjef.

Organisasjonen er liten, kompetansetung og personavhengig, med fleire roller som kombinerer operativ drift og styringsansvar.

Drift og arbeidsform

Selskapet kombinerer:

- lokal produksjon i sikra lokale
- digital produktutvikling og dokumentasjon i ein kombinasjon av sky- og onprem-løysingar
- bruk av eksterne leverandørar for enkelte komponentar og tenester

Utvikling skjer hovudsakleg i moderne, skybaserte verktøy, medan produksjonsutstyr og testmiljø er drifta lokalt (onsite). Fleire tilsette har ein fleksibel arbeidssituasjon, og noko arbeid – særleg innan programvare – blir utført frå heimekontor.

Aegir Systems AS er i vekst og vurderer å utvide både produksjonskapasitet og kundebase. Samstundes opplever leiinga at verksemda har gått frå å vere ei lita teknologigründerverksemd til å bli ein strategisk viktig leverandør, med tilhøyrande ansvar og forventningar. Sjølv om selskapet leverer til forsvarsindustrien, har den interne tryggleiken dessverre ikkje vore eit hovudsatsingsområde.

IT-bruk og digitale arbeidsprosessar

Aegir Systems AS er i stor grad avhengig av IT-system for dagleg drift, utvikling og samarbeid, sjølv om den mest sensitive produksjonen går føre seg lokalt. IT-landskapet har vakse gradvis og er prega av pragmatiske og kostnadseffektive val.

Programvareutvikling, algoritmedesign og tilhøyrande teknisk dokumentasjon skjer ved bruk av skybaserte utviklings- og samhandlingsverktøy. Kjeldekode, konfigurasjonar og tekniske skildringar blir lagra i skybaserte kode- og dokumentasjonsplattformer. Tilgang blir hovudsakleg styrt gjennom brukarkontoar, og samarbeid skjer både frå kontor og heimekontor.

Den utvikla programvaren og konfigurasjonsdataa inngår som ein del av den fysiske komponenten som blir produsert lokalt. Produksjonsmiljøet er fysisk skilt frå utviklingsmiljøet, men blir støtta av lokalt drifta IT-system for styring av produksjonsparametrar, logging og kvalitetssikring, samt dokumentasjon av kalibrering og testresultat. Desse systema er tett knytte til spesialisert produksjons- og testutstyr.

Overføring av programvare, konfigurasjonar og teknisk dokumentasjon frå utvikling til produksjon skjer gjennom definerte overleveringar. Samstundes er delar av prosessen personavhengige, og nøkkelpersonell sit med detaljkunnskap om samanhengen mellom programvare, produksjonsparametrar og ferdig produkt.

Verksemda har ein aktiv skystrategi og nyttar i hovudsak standardiserte skytjenester («hylleware») for å støtte administrative og forretningsmessige funksjonar. Dette gjer at selskapet kan konsentrere seg om kjerneverksemda. Administrasjon og støttefunksjonar nyttar skybaserte forretningssystem for økonomi og fakturering, HR og personaloppfølging, samt e-post og intern kommunikasjon. Det finst ingen dedikert IT- eller tryggleiksansvarleg. Drift, brukartilgang og tekniske avgjerder blir i hovudsak handterte av CTO, med støtte frå eksterne leverandørar ved behov.

Fleire tilsette nyttar berbare arbeidsstasjonar både på kontoret og heime. Det er varierende praksis for lagring av arbeidsfiler, bruk av eksterne lagringsmedium og handtering av tilgangar. Nokre senioringeniørar har utvida rettar for å kunne løyse komplekse tekniske problemstillingar effektivt.

Selskapet er i ferd med å inngå nye kontraktar som kan innebere tettare integrasjon med kundesystem, auka krav til dokumentasjon av utviklings- og produksjonsprosessar, samt meir strukturert handtering av tilgang, logging og sporbarheit. Leiinga er klar over at IT-bruken er forretningskritisk, men opplever at tempo, konfidensialitet og operativ effektivitet ofte blir prioriterte framfor formelle prosessar.

Oppgave 1: Sikkerheitsstrategi og etterleving (4 sider)

Skildring: Selskapet planlegg å levere produkt til fleire kundar og nye marknader. Dette medfører auka krav til dokumentert etterleving og digital tryggleik for å oppnå og halde ved lag marknadstilgang.

Du er engasjert som ekstern konsulent i YouFearWeProfit AS og har fått i oppdrag å bistå Aegir Systems AS med å strukturere og gjennomføre naudsynt etterlevingsarbeid for å møte desse krava.

Oppgåver:

1. Drøft kva omgrepa konfidensialitet, integritet og tilgjenge vil seie for tryggleiksarbeidet i Aegir Systems AS.
2. Lag ein overordna prosjektplan for korleis verksemda kan oppnå etterleving av NIS2 kapittel 4, artikkel 20 og 21. Prosjektplanen skal innehalde hovudfasar, milepålar og sentrale leveransar, men ikkje detaljert teknisk implementering.
(Lenkje NIS2: https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:32022L2555#cpt_IV).
3. Drøft kva organisatoriske og styringsmessige konsekvensar NIS2 – artikkel 24 kan få for verksemda.
4. Utarbeid ein kort, overordna tryggleikspolicy (maks 1 side) som fastset mål og prinsipp for verksemda sitt GRC-arbeid knytt til NIS2. Relevante føresegner i kapittel 4 skal speglast i policyen og kan visast til med artikkelnummer og bokstav.

Oppgave 2: Strategisk risikovurdering (8 sider)

Skildring: Som ein del av arbeidet med NIS2-etterleving skal det innførast risikostyring. Det første steget i denne prosessen er å gjennomføre ei strategisk risikovurdering av den digitale tryggleiken i verksemda. Denne vurderinga skal leggje grunnlaget for den vidare tryggleikssatsinga. I oppgåve 2.1 etablerer du konteksten som blir nytta for å svare på oppgåve 2.2, 2.3 og 2.4.

Oppgaver:

1. For å **etablere og avgrense kontekst** i risikovurderinga skal du:
 - Identifisere og skildre verksemda sine viktigaste leveransar/tenester.
 - Kartleggje og skildre dei fire mest sentrale kjerneprosessane som er naudsynte for å levere desse.
 - Avgrense konteksten for risikovurderinga basert på leveransar og kjerneprosessar.
2. **Verdi-, trussel- og sårbarheitsvurdering:**
 - Gjennomfør ei verdivurdering innanfor konteksten du har definert. Identifiser og skildre dei ti viktigaste digitale verdiane verksemda forvaltar (til dømes informasjon, system, programvare, konfigurasjonar eller data). Klassifiser kvar verdi med omsyn til krav til konfidensialitet, integritet og tilgjenge (CIA).
 - Gjennomfør ei trusselvurdering for verksemda. Fokuser på dei fem viktigaste trusselaktørane og analyser motivasjon, intensjon, evne, kompetanse (know-how) og vilje til å angripe Aegir Systems AS. Vurderingane skal vere grunngevnne i verksemda si rolle, teknologi og marknad.
 - Gjennomfør ei overordna sårbarheitsvurdering av Aegir Systems AS innanfor den definerte konteksten. Identifiser kvar verksemda er mest eksponert i organisasjon, IT- og produksjonsmiljø, leveransar og kjerneprosessar. Sårbarheitene skal presenterast strukturert (til dømes i tabellform) og prioriterast i tråd med kritikalitet.

3. Overordna risikovurdering:

- Gjennomfør ei strategisk risikovurdering av verksemda og kartlegg uakseptabel risiko på eit overordna nivå. Bruk arbeidet frå verdi-, trussel- og sårbarheitsvurderingane til å forankre risikoane.
- **Visualisering:** Bruk visuelle verkemiddel aktivt til å framstille risikobiletet, forklare kritiske risikoar og overtyde mottakaren.

4. Tiltaksanbefaling:

- Oppsummer funna dine med fem til ti tiltaksråd til leiinga i verksemda for å redusere risiko og sikre verksemda og tenesteleveransane. Samordne gjerne tiltaka med strategi og NIS2-arbeidet frå oppgåve 1.
- Skriv eit notat til leiinga om kvifor dei bør investere i tiltaksplanen din. Bruk logos, pathos og ethos aktivt for å overtyde. Du kan òg nytte visuelle verkemiddel for å styrkje argumentasjonen.

Oppgave 3: Avvik- og hendelseshandtering (3 sider)

Skildring: Ein utviklar i Aegir Systems AS oppdagar at ei intern konfigurasjonsfil med produksjonsparametrar og krypteringsnøklar ligg tilgjengeleg i eit skybasert utviklingsmiljø med breiare tilgang enn føresett. Fila inneheld sensitiv informasjon knytt til både programvare og produksjonsoppsett.

Oppgåver:

1. Avvikssystem:

- Skildre og utforme ein prosess for avvikshandtering i Aegir Systems AS, frå innmelding til avviket er ferdighandtert og lukka (non-conformity).
- Bruk avviket skildra ovanfor som døme på avviksbehandlinga.

Eskalering: Forholdet blir registrert som eit avvik i verksemda sitt kvalitetssystem og blir først klassifisert som «feil tilgangskonfigurasjon», og handtert deretter. Nokre dagar seinare får verksemda ei henvending frå ein samarbeidspartnar som har observert uvanleg trafikk knytt til miljøa til Aegir Systems. Det viser seg at ei ekstern IP-adresse har hatt tilgang til utviklingsplattforma i perioden fila var eksponert.

2. Hendingshandtering:

- Forklar skilnaden mellom avvik og tryggleikshending (incident). Drøft når og kvifor avviket i scenarioet bør reklassifiserast til ei tryggleikshending, og kva forhold som kan føre til vidare eskalering til krise.
- Skildre kva hovudelement som bør inngå i ein plan for hendingshandtering (incident response plan) for Aegir Systems AS. Bruk konkrete døme frå verksemda si organisering, teknologi og leveransar.
- Skildre korleis hendinga i scenarioet bør handterast steg for steg i tråd med beste praksis. Gjer òg greie for kva IT-systemstøtte verksemda vil vere avhengig av for effektiv hendingshandtering.

Deklarasjon for bruk av KI-verktøy og hjelpemiddel

Sjekklista nedanfor skal svarast på:

- **Tekstkorreksjon:** Er delar av teksten sjekka med verktøy som Grammarly, Ginger, LanguageTool eller liknande? Ja / Nei
- **Tekstgenerering:** Er delar av teksten genererte av verktøy som ChatGPT, Jasper, WriteSonic eller liknande? Ja / Nei
- **Skriveassistanse:** Har nokre av rapporten sine idear eller tilnærmingar blitt føreslått av verktøy som ChatGPT, Google Bard eller liknande? Ja / Nei
- **Bildegenerering:** Er nokre bilete/figurar i rapporten genererte av verktøy som Midjourney, DALL·E eller liknande? Ja / Nei
- **Andre KI-verktøy:** Har du brukt andre KI-verktøy? Dersom ja, spesifiser her:

Har du brukt KI-baserte verktøy eller hjelpemiddel i utarbeidinga av denne rapporten?
Dersom ja, spesifiser verktøyet og bruksområdet nedanfor.

1. **Tekstgenerering** – Dersom du har brukt teksthjelpemiddel/verktøy, kva oppgåver blei løyste ved hjelp av KI, og korleis?
2. **Bilete, tabellar og figurar** – Dersom du har brukt bilete-/figurgeneratorar, kva bilete/diagram er KI-genererte?

Eg erklærer at all bruk av KI-verktøy eller hjelpemiddel er tydeleg oppgitt anten i rapporten eller i dette deklarasjonsskjemaet.

Kandidatnr / Dato